INFORME EJECUTIVO: Blue team

Fecha: 22 de junio de 2026
Autora: Sonia Rando

1. RESUMEN EJECUTIVO

Se ha completado una auditoría forense integral sobre los registros de actividad del servidor web. El análisis confirma una actividad hostil coordinada y automatizada, dirigida a la identificación de vectores de ataque y la explotación de vulnerabilidades en la capa de aplicaciones. Se ha clasificado el riesgo global como **MEDIO-ALTO**. Tras la correlación de eventos, se ha validado un incidente de seguridad crítico: el 19 de junio de 2026, una campaña de fuerza bruta logró comprometer el panel de administración de bases de datos, permitiendo al atacante el control sobre el motor de bases de datos. Otros ataques, como inyecciones SQL y denegación de servicio (DoS), fueron detectados y contenidos en el perímetro.

2. ANÁLISIS DETALLADO DE HALLAZGOS

El siguiente cuadro técnico desglosa los vectores de ataque identificados y el impacto asociado a cada uno:

Tipo de Ataque	Estado	Impacto Técnico
Fuerza Bruta Web	Exitoso	Compromiso de credenciales administrativas; acceso total a la BD.
Reconocimiento (Nmap)	Detectado	Mapeo activo de puertos, servicios y versiones de software.
Inyección SQL (SQLi)	Contenido	Intento fallido de extracción de registros mediante manipulación de queries.
DoS (HTTP Flood)	Detectado	Saturación de recursos

Tipo de Ataque	Estado	Impacto Técnico
		mediante peticiones HTTP concurrentes.

3. CONCLUSIONES E IMPACTO

La brecha de seguridad identificada resalta debilidades estructurales significativas en la arquitectura actual:

- **Exposición de Activos Críticos:** La accesibilidad pública del panel de gestión de bases de datos permitió la ejecución del ataque de fuerza bruta.
- **Debilidad en la Capa de Aplicación:** La persistencia de vulnerabilidades tipo Inyección SQL sugiere una falta de validación de entradas en el ciclo de vida del desarrollo.
- **Deficiencia en la Postura Defensiva:** La ausencia de un Web Application Firewall (WAF) impidió la mitigación proactiva de los intentos de escaneo y explotación automatizada.

4. RECOMENDACIONES Y PLAN DE REMEDIACIÓN

Se recomienda la ejecución inmediata del siguiente plan de acción para restablecer la integridad de la plataforma:

Fase 1: Contención (Prioridad Alta)

- Bloqueo perimetral de las direcciones IP maliciosas detectadas en los logs.
- Restablecimiento forzado de todas las credenciales administrativas y de bases de datos.
- Auditado forense de los logs para verificar el alcance de la exfiltración de datos.

Fase 2: Fortalecimiento (Hardening)

- **Implementación de WAF:** Desplegar una solución de firewall para filtrar tráfico basado en firmas y comportamiento anómalo.
- **Segmentación de Red:** Migrar todos los paneles de administración y servicios críticos a un entorno restringido (VPN corporativa).
- **Configuración de Rate Limiting:** Establecer umbrales estrictos de peticiones para mitigar ataques de fuerza bruta y DoS.

Fase 3: Desarrollo Seguro

- Implementación obligatoria de **Prepared Statements** para todas las interacciones con la base de datos.
- Realización de un escaneo de vulnerabilidades dinámico (DAST) sobre todo el entorno web tras aplicar los parches.
